

Preventing Social Engineering Attacks: Essential Defense Strategies

Social engineering is one of the most common forms of cyberattack today. With much of our lives taking place online, the risk of being attacked using social engineering is increasing: in 2024 alone, more than 80% of cyberattacks in the UK are phishing attacks. Next is impersonation (creating a pretext). In comparison, only about 14% of cyberattacks and breaches are caused by malware.

Social engineering attacks can have devastating consequences, ranging from financial losses to identity theft or serious security breaches with millions of data points leaked and systems compromised. Being able to recognize when you are under a social engineering attack and how to respond effectively to prevent serious damage is extremely important.

In this article, you will find detailed explanations of what social engineering is and how it works, along with suggestions on how to prevent social engineering attacks at both the individual and organizational levels.

Understanding Social Engineering

Generally speaking, social engineering is a way to influence attitudes and behavior. It encompasses various social skills and techniques used to persuade someone to disclose information or perform certain actions. However, in different contexts, social engineering can have different meanings. Here, I am discussing social engineering in the context of information security.

What is social engineering?

In the context of information security, social engineering is primarily a psychological manipulation tactic. Typically, an individual can use social engineering attacks to:

Obtaining information and/or access to IT systems with the goal of a deeper attack. For example, someone might impersonate a customer support representative over the phone or video call to trick the target into handing over control of their device in order to infect it with malware. These attacks can occur both in person and online.

These attacks utilize technology in combination with manipulative techniques to achieve other goals, such as email or SMS phishing to obtain banking information, social security numbers, and other data in order to steal money and identity. These attacks are typically carried out online, not in person.

Common Social Engineering Techniques



Types of social engineering attacks

There are many types of social engineering attacks, some more common than others.

Phishing

Phishing involves both social engineering and deception to trick unsuspecting victims into revealing sensitive information such as bank details, login credentials, and other information. The most common phishing attacks take the form of spam emails, messages, or websites that appear to be legitimate sources. For example, they may look like they're from a bank, social media site, delivery service, and other sources. The messages often seem urgent but are also quite generic.

There are varying degrees of phishing attacks: some can be more sophisticated and complex. For example, in a personalized phishing attack called targeted phishing, the attacker might impersonate a specific person you may know or use other publicly available information about the victim to create a more personalized attack. Targeted phishing is often harder to detect and has a much higher success rate than regular phishing attacks.

Pretexting

This social engineering technique involves using a fabricated scenario – a pretext – to gain the victim's trust and trick them into revealing information. Creating a pretext often requires research from the attacker. For example, they might use your personal information to impersonate you, or offer to provide credentials to prove the legitimacy of their pretext. An example of such an attack might be someone posing as a customer support representative or bank employee to trick you into revealing personal information or granting access to secure devices and systems.

Scareware

Threat software is a type of attack that uses fake threats, alerts, or offers prompting you to take urgent action. For example, you might receive a pop-up window saying your device has been infected with malware, and a button prompting you to install antivirus software, which will often be infected with the actual malware.

Baiting

Decoy attacks, as the name suggests, involve using bait to pique a victim's curiosity. In the physical world, such decoys are often malware-infected USB drives left in conspicuous places, and similar devices that can spread malware to other devices. Online, decoys take the form of enticing advertisements leading to malicious websites or encouraging users to install malware-infected applications.

What for whom?

Quid pro quo means "one for another" in Latin, and as the name suggests, these attacks are often carried out by people offering compensation in exchange for

information. Someone might pretend to be a researcher asking you to participate in a survey in exchange for money.

Water Holding

Watertrap attacks rely on the trust users have in websites they frequently visit. Attackers can observe the websites an organization or individual visits most often and infect them with malware or malicious links. When a victim clicks on a link or otherwise interacts with the infected website, their device becomes infected and the attacker gains access to the entire company system. This social engineering strategy has been used to infiltrate systems that were previously considered highly secure.

Why is social engineering effective?

The success of social engineering lies in the fact that humans are flawed creatures and therefore easily susceptible to manipulative tactics. According to one...Survey on social engineering attacks in 2019“Socially motivated attacks are carried out through relationships with victims to influence their psychology and emotions. [They] are the most dangerous and successful type of attack because they involve human interaction.” These attacks rely more on human factors than on technical system vulnerabilities. Exploiting human weaknesses such as trust, a sense of security, and the tendency to help others or seek the most convenient path is easier.

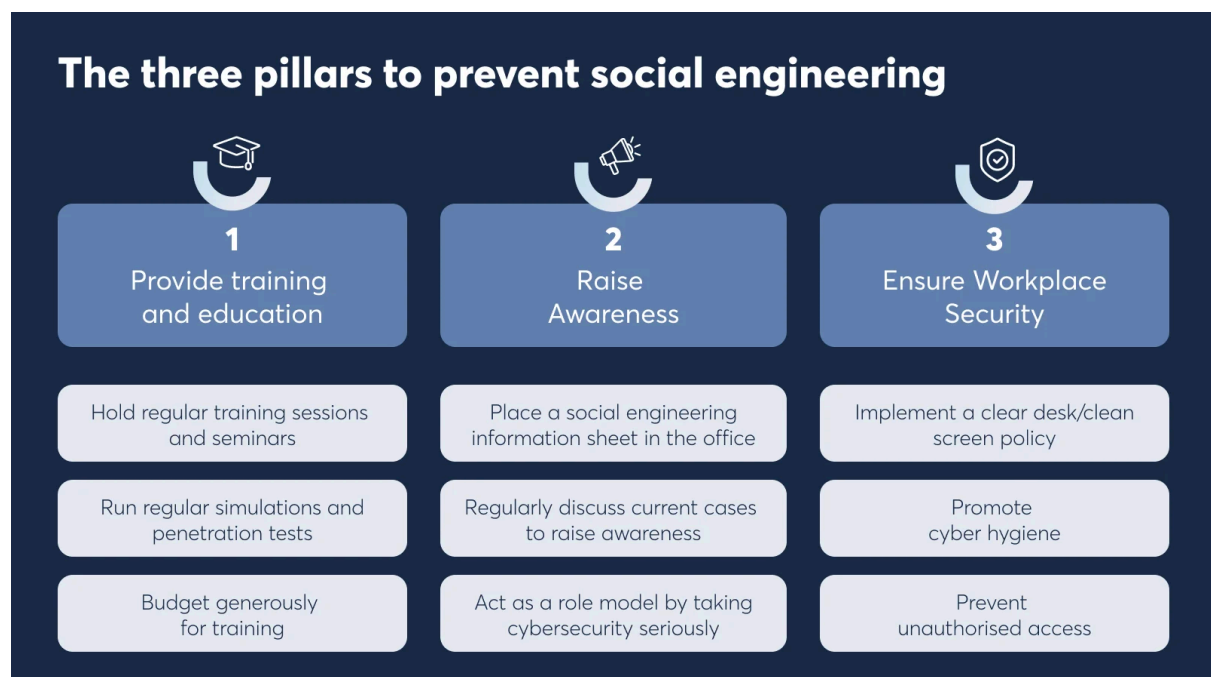
People tend to make more mistakes when they are distracted, feeling pressured, rushed, or empathetic. That's why attacks that call for urgent action (like flashing alerts about a virus-infected device) or appeal to empathy (like fake fundraising campaigns or someone you may know is in need of help) often have a high success rate.

Furthermore, social engineering attacks are more difficult to detect and prevent. They leave no technical trace, and most prevention methods rely on ongoing training. A lack of technical or general knowledge is another problem: people unfamiliar with malware or phishing are more vulnerable. Training someone to recognize and counter social engineering attacks is more challenging than implementing technical security measures.

How to prevent social engineering attacks

Preventing social engineering attacks is often quite challenging, and technical solutions aren't always the answer. Successful prevention relies almost entirely on training individuals to recognize the signs of a social engineering attack and how to counter and report it. Therefore, the risk of human error never truly disappears.

But this doesn't mean social engineering attacks can't be prevented. Teaching users warning signs and how to react is the first step in protecting themselves, their company, and their information from malicious actors.



Recognize the warning signs.

All social engineering attempts have a few things in common. Here are some of the most common signs that might indicate someone is trying to carry out a social engineering attack:

Unexpected phone calls. If you receive an unexpected call, especially if the caller claims to be from a bank, insurance company, or IT firm, it's very likely a scam. Do not provide any personal information and avoid answering any questions.

The sender's email address is suspicious. If something feels off about an email you receive, always check the sender's email address. If it contradicts the

sender's name and the email's subject line, contains numbers or symbols, and generally looks suspicious, it could be spam.

An unusual request from someone you know. If your company's CEO contacts you with urgent requests for money, login credentials, documents, and other information, even though they've never done so before, it could be a scam. Always verify with someone you know if it was actually them who sent the email or message.

An urgent request or demand. Scamming attempts always have a sense of urgency, such as “pay now” or “act quickly,” and similarly, are designed to make you feel pressured, distracted, and overwhelmed. Don’t act immediately and try to calmly assess the situation. Legitimate organizations will communicate in a clear, neutral tone that doesn’t create a sense of urgency or fear.

Unexpected links or attachments Do not open attachments or click on links in emails you don't expect. They may be malicious and lead to harmful websites. Before clicking on links, hover over the text, and if the links don't match the text, they may be spoof. Scammers may also shorten URLs **to hide the actual destination of the link.**

The layout and spelling are unusual. Incorrect grammar and spelling, unusual sentence structure, and inconsistent formatting are strong indicators of a phishing attempt. Legitimate organizations have dedicated staff to create, review, and approve all correspondence, including emails, text messages, newsletters, and other documents.

A generic greeting/signature. A greeting that doesn't include your name, such as "Dear Mr./Ms.," and a signature without contact information (or with illogical contact information) are strong indicators of a phishing email. Legitimate organizations such as banks, insurance companies, delivery services, and others will include a personal greeting and contact information.

The offers seem too good to be true. If an offer seems too good to be true, such as a large sum of money in exchange for information that seems insignificant, it could be a scam.

A request on social media from someone you don't recognize. Malicious actors use social media to impersonate business accounts and influencers. Be wary of such messages, especially if they're from someone you don't know.

Defenses against socio-technical attacks

Anyone can become a victim of a social engineering attack, as they are designed to exploit human weaknesses. The best way to defend against such attacks is to operate on a "don't trust" mindset: don't trust anyone and always double-check sources, messages, attachments, and other elements. However, there are still some technical and human-related defenses you can take to mitigate the risk of social engineering.

Activate the spam filter.

Most email services today offer spam filters, which mark suspicious emails as spam, warn you before opening a suspicious file or email, or send emails previously marked as spam directly to the trash. However, don't rely solely on spam filters; you must still think critically, be suspicious, and maintain a distrustful mindset.

Implement multi-factor authentication

Multi-factor authentication, in particular MFA combats fraud. This is crucial in preventing unauthorized logins, security breaches, and the theft of sensitive data. Authentication information such as passwords, email addresses, and usernames can still be obtained through social engineering attacks. Requiring an extra step, such as biometric authentication, security questions, one-time passwords, and/or codes, significantly reduces the risk of compromise even if malicious actors already have your login credentials.

Employee awareness training

Because social engineering relies on exploiting human flaws and weaknesses, regular training at the organizational level is crucial to ensuring the safety of your employees and data. All your employees should be informed and taught how to use defenses such as multi-factor authentication, the importance of strong passwords, and firewall usage. Teaching them to recognize and respond

to signs of social engineering will significantly improve your organization's security where technical defenses are lacking.

How to protect yourself from social engineering

There are several steps you can take to protect yourself from social engineering attacks:

- Adopt a "doubt-based" mindset. Always assume that external communications may be a social engineering effort, and be cautious, seeking clear, undeniable evidence that the message is legitimate.
- Familiarize yourself with the signs of social engineering. Anyone can fall victim to social engineering, especially those who think they are immune to such tactics. Protect yourself by educating yourself about warning signs and preventative measures.
- Use technical defenses, such as strong passwords, multi-factor authentication, firewalls, spam filters, and other measures.
- Avoid sharing personal information online. This personal information can be used to manipulate you at any time. Monitor your social media profiles – keep them private and only share access with people you know personally. Keep your work and personal accounts separate. Do not send sensitive personal information via email, and do not respond to emails requesting this information.

Organizational strategy

Organizational strategies for preventing and defending against social engineering attacks may differ from those adopted by individuals, but they are still based on similar fundamental steps. Any company needs to develop a security awareness program that helps employees recognize the signs of social engineering attacks, implement necessary security measures, and know how to respond in the event of a successful attack. Additional measures such as incident response plans and regular security audits will help keep the organization secure in the long term.

Develop a security awareness program.

The most important thing is **regular training**. Research shows that ongoing training and testing improve employees' security awareness, reduce their

susceptibility to social media attacks, and encourage security-conscious behavior.

There are many ways to develop security awareness programs, from classic PowerPoint presentations to gamified competitions. Here are some examples of security training programs that could be implemented in your organization:

- Regular newsletters and training videos remind employees of important information.
- The online teaching materials are gamified, and there are "Detect Phishing" contests with prizes to encourage participation.
- Monthly phishing simulation exercises, such as intentionally sending phishing emails, followed by individual training for employees who consistently fail the tests.
- Different types of training correspond to different times of the year – from Christmas scams to tax-related scams during tax season, and so on.
- Specialized training is provided to different teams and roles on social attack tactics in which they may be vulnerable.

Here are some general tips when building a security awareness program for users:

- Keep processes and communication simple, and draft security policies in language that is easily understood by everyone. Your staff may have varying levels of security knowledge and experience, as well as different competencies and enthusiasms.
- Simplify security policies so that they don't interfere with existing workflows but instead complement them.
- Allocate training regularly. Training for a few hours once a year can be tiring, but 30 minutes each month will keep it fresh, interesting, and accessible.
- Experiment with training formats – you can see some examples above.
- Implement technical defenses, such as password managers with different access levels, firewalls, multi-factor authentication, regular security audits, and other measures.